

Informe “Kit de Encuesta ISO/IEC 27001:2022 sobre Indicadores y Métricas”

1. Introducción

Este informe describe un kit completo de encuesta diseñado para evaluar cómo las organizaciones definen, miden y utilizan indicadores y métricas de ciberseguridad alineados con ISO/IEC 27001:2022, con especial atención al contexto español y europeo (incluida NIS2). El objetivo no es solo saber si hay indicadores, sino si sirven para algo más que adornar presentaciones.

El documento integra: el modelo de cuestionario, la guía metodológica, la narrativa explicativa, el mapeo a requisitos normativos, una plantilla conceptual de cálculo de madurez y ROI, un guion de reporte ejecutivo y las instrucciones de uso del kit.

2. Modelo de encuesta integral

2.1 Descripción general

La encuesta está orientada a responsables de seguridad de la información (CISO), responsables de riesgos, continuidad de negocio y otros perfiles clave. Se estructura en 14 bloques temáticos:

1. Información general de la organización.
2. Gobernanza del SGSI e indicadores.
3. Diseño metodológico de indicadores.
4. Indicadores estratégicos y madurez del SGSI.
5. Gestión de riesgos.
6. Controles técnicos, vulnerabilidades y métricas operativas.
7. Monitorización, SOC e incidentes.
8. Concienciación y comportamiento del usuario.
9. Continuidad de negocio y resiliencia.
10. Proveedores y cadena de suministro.
11. Entorno regulatorio (NIS2, GDPR, etc.).
12. Automatización y calidad de datos.
13. Reporte, comunicación y uso de indicadores.
14. Futuro, mejora y madurez global.

Cada bloque combina preguntas cerradas y abiertas, con opciones cuidadosamente formuladas para permitir análisis cuantitativo y, a la vez, capturar matices cualitativos.

2.2 Estructura detallada (resumen por bloques)

- Bloque 1 – Información general
Caracteriza tipo de organización, sector, ámbito geográfico y estado de certificación/ alineamiento con ISO/IEC 27001. El fin es poder segmentar posteriormente los resultados (público/privado, sector crítico/no crítico, etc.).
- Bloque 2 – Gobernanza e indicadores
Indaga si existe un sistema formal de indicadores, su nivel de aprobación, la frecuencia con la que se revisan en órganos de gobierno y la cobertura frente a los objetivos del SGSI.
- Bloque 3 – Diseño metodológico
Explora el uso de criterios formales (por ejemplo, enfoque SMART), las referencias a normas y guías (ISO 27001, ISO 27004, ISACA, ENISA, INCIBE) y el peso relativo de distintas dimensiones: riesgo, rendimiento, cumplimiento, madurez y resiliencia.
- Bloque 4 – Estrategia y madurez
Pregunta por la existencia de un indicador global de madurez del SGSI, la frecuencia con la que se presenta a la alta dirección y el uso de métricas económicas (incluido ROI de seguridad) para orientar inversiones.
- Bloque 5 – Gestión de riesgos
Se centra en KRIs y otros indicadores que midan el estado del proceso de gestión de riesgos (porcentaje de activos analizados, riesgos tratados en plazo, riesgos residuales por encima del apetito, excepciones abiertas, etc.).
- Bloque 6 – Controles técnicos y vulnerabilidades
Revisa la presencia de métricas relacionadas con vulnerabilidades y parches (tiempos de corrección, cobertura de sistemas, exposición de activos en internet) y con la “higiene básica” (antivirus/EDR, configuraciones seguras, cifrado).

- Bloque 7 – Monitorización, SOC e incidentes
Se centra en indicadores como número y gravedad de incidentes, MTTD/MTTR, cumplimiento de SLA, reincidencias, así como KPIs específicos del SOC (cobertura de fuentes, correlación, disponibilidad, detección avanzada).
- Bloque 8 – Concienciación y comportamiento
Interroga sobre KPIs de formación, simulaciones de phishing, reporting de incidentes por usuarios y posibles mecanismos de incentivos o consecuencias ligados a estos indicadores.
- Bloque 9 – Continuidad y resiliencia
Aborda métricas de continuidad de negocio y recuperación ante desastres: porcentaje de procesos críticos con planes actualizados, pruebas realizadas, cumplimiento de RTO/RPO y análisis de desviaciones en pruebas.
- Bloque 10 – Proveedores y cadena de suministro
Revisa si se miden el desempeño de seguridad de terceros críticos y qué indicadores se utilizan (evaluaciones, cláusulas de seguridad, incumplimientos de SLA, incidentes asociados).
- Bloque 11 – Regulación y entorno externo
Mira el grado de alineamiento percibido con NIS2, el uso de indicadores de protección de datos y la utilización de referencias nacionales o europeas (como estadísticas de INCIBE o ENISA) como benchmarks.
- Bloque 12 – Automatización y calidad de datos
Pregunta por el nivel de automatización en la recogida de datos, las herramientas empleadas (GRC, BI, hojas de cálculo, desarrollo propio) y la evaluación (formal o no) de la calidad de los datos.
- Bloque 13 – Reporte y uso práctico
Identifica los receptores principales de los informes de indicadores, la frecuencia de reporte y el grado de influencia real en la toma de decisiones.

-

Bloque 14 – Futuro y madurez global

Recoge prioridades de mejora, el nivel de madurez global del sistema de indicadores (escala de 1 a 5) y comentarios abiertos que permitan comprender el contexto y los “dolores” particulares de cada organización.

Bloque 1 – Información general

Caracteriza tipo de organización, sector, ámbito geográfico y estado de certificación/ alineamiento con ISO/IEC 27001. El fin es poder segmentar posteriormente los resultados (público/privado, sector crítico/no crítico, etc.).

Bloque 2 – Gobernanza e indicadores

Indaga si existe un sistema formal de indicadores, su nivel de aprobación, la frecuencia con la que se revisan en órganos de gobierno y la cobertura frente a los objetivos del SGSI.

Bloque 3 – Diseño metodológico

Explora el uso de criterios formales (por ejemplo, enfoque SMART), las referencias a normas y guías (ISO 27001, ISO 27004, ISACA, ENISA, INCIBE) y el peso relativo de distintas dimensiones: riesgo, rendimiento, cumplimiento, madurez y resiliencia.

Bloque 4 – Estrategia y madurez

Pregunta por la existencia de un indicador global de madurez del SGSI, la frecuencia con la que se presenta a la alta dirección y el uso de métricas económicas (incluido ROI de seguridad) para orientar inversiones.

Bloque 5 – Gestión de riesgos

Se centra en KRIs y otros indicadores que midan el estado del proceso de gestión de riesgos (porcentaje de activos analizados, riesgos tratados en plazo, riesgos residuales por encima del apetito, excepciones abiertas, etc.).

Bloque 6 – Controles técnicos y vulnerabilidades

Revisa la presencia de métricas relacionadas con vulnerabilidades y parches (tiempos de corrección, cobertura de sistemas, exposición de activos en internet) y con la “higiene básica” (antivirus/EDR, configuraciones seguras, cifrado).

Bloque 7 – Monitorización, SOC e incidentes

Se centra en indicadores como número y gravedad de incidentes, MTTD/MTTR, cumplimiento de SLA, reincidencias, así como KPIs específicos del SOC (cobertura de fuentes, correlación, disponibilidad, detección avanzada).

Bloque 8 – Concienciación y comportamiento

Interroga sobre KPIs de formación, simulaciones de phishing, reporting de incidentes por usuarios y posibles mecanismos de incentivos o consecuencias ligados a estos indicadores.

Bloque 9 – Continuidad y resiliencia

Aborda métricas de continuidad de negocio y recuperación ante desastres: porcentaje de procesos críticos con planes actualizados, pruebas realizadas, cumplimiento de RTO/RPO y análisis de desviaciones en pruebas.

Bloque 10 – Proveedores y cadena de suministro

Revisa si se miden el desempeño de seguridad de terceros críticos y qué indicadores se utilizan (evaluaciones, cláusulas de seguridad, incumplimientos de SLA, incidentes asociados).

Bloque 11 – Regulación y entorno externo

Mira el grado de alineamiento percibido con NIS2, el uso de indicadores de protección de datos y la utilización de referencias nacionales o europeas (como estadísticas de INCIBE o ENISA) como benchmarks.

Bloque 12 – Automatización y calidad de datos

Pregunta por el nivel de automatización en la recogida de datos, las herramientas empleadas (GRC, BI, hojas de cálculo, desarrollo propio) y la evaluación (formal o no) de la calidad de los datos.

Bloque 13 – Reporte y uso práctico

Identifica los receptores principales de los informes de indicadores, la frecuencia de reporte y el grado de influencia real en la toma de decisiones.

Bloque 14 – Futuro y madurez global

Recoge prioridades de mejora, el nivel de madurez global del sistema de indicadores (escala de 1 a 5) y comentarios abiertos que permitan comprender el contexto y los “dolores” particulares de cada organización.

3. Guía metodológica

3.1 Propósito

La guía metodológica sirve para que el responsable del estudio aplique la encuesta de forma coherente, evitando que cada organización interprete las preguntas de manera radicalmente distinta. Explica de dónde viene la encuesta, qué pretende y cómo deben analizarse los resultados.

3.2 Fundamentos normativos

La encuesta se apoya en:

- ISO/IEC 27001:2022, que exige definir qué se mide, cómo y con qué frecuencia, y utilizar los resultados para evaluar el desempeño del SGSI y apoyar la mejora continua.
- ISO/IEC 27004, que desarrolla conceptos de medición y propone enfoques para diseñar métricas útiles.
- Guías de ISACA sobre sistemas de KPIs y medición de la función de seguridad, que ayudaron a estructurar categorías de indicadores (KPIs, KRIs, indicadores de cumplimiento, de madurez, etc.).
- Prácticas recientes de “continuous compliance” y gestión de KPIs ISO 27001, donde la automatización y la integración con herramientas GRC ganan protagonismo.
- Informes de organismos como INCIBE y ENISA, que ponen en contexto nacional y europeo los incidentes y amenazas.

3.3 Población y muestreo

El público objetivo incluye:

- CISOs y responsables de seguridad de la información.
- Responsables de riesgos y cumplimiento.
- Responsables de continuidad de negocio y resiliencia.
- En su defecto, responsables de TI con atribuciones de seguridad.

Según el proyecto, el muestreo podrá ser por sector (por ejemplo, sanitario), por territorio (por ejemplo, una comunidad autónoma) o por tipo de entidad (operadores esenciales NIS2). Lo importante es documentar claramente el ámbito de aplicación.

3.4 Aplicación práctica

Se recomienda:

- Usar un formulario online que reproduzca fielmente las preguntas y codificaciones.
- Permitir guardar respuestas parciales.
- Estimar 30–45 minutos por respuesta.
- Ofrecer un punto de contacto para aclarar dudas interpretativas.

3.5 Escalas y análisis

Las preguntas se han diseñado con:

- Escalas 1–5 en peso, madurez o alineamiento.
- Opciones cerradas mapeables a enteros.
- Ítems multiselección representados como variables binarias.

A partir de estas respuestas se pueden construir:

- Subíndices por bloque (gobernanza, riesgos, técnicos, etc.).
- Un índice global de madurez (IGM).
- Índices temáticos (resiliencia, terceros, cultura, etc.).
- Indicadores económicos (ROI de seguridad, coste por incidente, etc.).

4. Narrativa explicativa

4.1 Sentido de la encuesta

La narrativa acompañante cumple dos funciones: explicar a las personas encuestadas qué hay detrás de tanta pregunta y, de paso, lanzar un suave recordatorio de que medir no es un fin en sí mismo, sino una forma de gobernar mejor el riesgo.

Se insiste en:

- La distancia habitual entre “lo que creemos medir” y “lo que realmente medimos”.
- La utilidad de indicadores que conectan con decisiones concretas, frente a métricas decorativas.
- La necesidad de que los indicadores dialoguen con las exigencias de ISO 27001, ISO 27004, NIS2 y el contexto nacional.

4.2 Uso interno y uso externo

Internamente, la encuesta actúa como espejo: muestra fortalezas, debilidades, incoherencias y prioridades. Externamente, agregando resultados:

- Permite elaborar panoramas sectoriales o territoriales.
- Informa a reguladores y diseñadores de políticas.
- Muestra si las organizaciones están midiendo aquello que los marcos internacionales y nacionales consideran crucial.

5. Mapeo de preguntas a requisitos normativos

El kit incorpora un mapeo que relaciona cada bloque de la encuesta con:

- Cláusulas de ISO/IEC 27001:2022 (4–10 y Anexo A).
- Conceptos de medición de ISO/IEC 27004.
- Categorías de KPIs y orientaciones de guías de ISACA.
- Marcos regulatorios relevantes (NIS2, GDPR, lineamientos nacionales).

Ejemplos de alineamiento:

- Bloques 2 y 3 se alinean fuertemente con la exigencia de ISO 27001 de definir qué se mide, cómo y cuándo, y con las recomendaciones de ISO 27004 e ISACA sobre diseño de sistemas de KPIs y KRIs.
- Bloques 5 y 6 conectan con las secciones de gestión de riesgos y controles técnicos del Anexo A, y con métricas típicas de vulnerabilidades, exposición de activos y tiempos de corrección.
- Bloque 7 enlaza con controles de gestión de incidentes y monitorización, y con prácticas recogidas en informes de amenazas de ENISA y datos nacionales sobre incidentes.
- Bloques 9 y 10 se relacionan con los controles de continuidad y cadena de suministro, claves también en NIS2.
- Bloques 11 y 12 exploran la alineación con marcos regulatorios y el grado de madurez en automatización y calidad de datos, anticipando expectativas de supervisores y auditores.

Este mapeo permite usar los resultados no solo como diagnóstico interno, sino como evidencia de alineamiento (o falta de él) con la norma y el entorno regulatorio.

6. Plantilla para cálculo de IGM y ROI

6.1 Índice Global de Madurez (IGM)

El IGM se concibe como un índice compuesto basado en:

- Subíndices por bloque (gobernanza, metodología, riesgos, técnicos, incidentes, concienciación, resiliencia, regulación).
- Ponderaciones configurables por bloque y, opcionalmente, por pregunta.

Esquema típico:

- Normalizar las respuestas numéricas de cada pregunta a una escala 0–1.
- Calcular subíndices de bloque como suma ponderada de respuestas normalizadas.
- Calcular el IGM como suma ponderada de los subíndices.
- Interpretar el resultado en 5 niveles de madurez:
 - 0,00–0,19 → Nivel 1 – Reactivo.
 - 0,20–0,39 → Nivel 2 – Básico.
 - 0,40–0,59 → Nivel 3 – Definido.
 - 0,60–0,79 → Nivel 4 – Gestionado.
 - 0,80–1,00 → Nivel 5 – Optimizado.

Además, se pueden construir subíndices temáticos (riesgos, cultura, resiliencia, terceros) para orientar planes de acción más precisos.

6.2 ROI y métricas económicas

La plantilla incluye la idea de:

- Recoger costes de seguridad (CAPEX, OPEX).
- Recoger costes asociados a incidentes (pérdidas, sanciones, indisponibilidades).
- Estimar pérdidas evitadas gracias a determinadas medidas de seguridad.
- Calcular un ROI de seguridad orientativo:
(ROI = (Pérdidas\ evitadas - Coste\ de\ seguridad) / Coste\ de\ seguridad)

También se sugieren métricas de eficiencia:

- Coste por punto de IGM.
- Coste por incidente gestionado.
- Coste por unidad de reducción del tiempo de indisponibilidad.

No se pretende una exactitud financiera absoluta, sino una aproximación razonable que permita hablar de seguridad en el lenguaje de la dirección financiera.

7. Plantilla de reporte ejecutivo

7.1 Objetivo del reporte

La plantilla de presentación (PowerPoint u otra) sintetiza los resultados para fóruns ejecutivos. Su lógica es contar una historia clara:

15. Qué se ha hecho y por qué.
16. Qué se ha encontrado (IGM, subíndices, brechas).
17. Qué significa en términos de riesgo, cumplimiento y resiliencia.
18. Qué se recomienda hacer y con qué prioridad.

7.2 Estructura propuesta

- Portada y contexto.
- Metodología resumida.
- Perfil de la muestra.
- IGM global y distribución.
- Resultados por bloque (gobernanza, riesgos, técnicos, incidentes, etc.).
- Relación con NIS2, GDPR y referencias nacionales/europeas.
- Nivel de automatización y calidad de datos.
- Resultados económicos (ROI) si se dispone de datos.
- Áreas de mejora y hoja de ruta en tres horizontes temporales.
- Cierre y llamada a la acción.

8. README del kit y uso recomendado

8.1 Pasos para usar el kit

19. Definir el alcance (sector, territorio, tipo de organización).
20. Revisar y adaptar la encuesta lo justo para el contexto específico.
21. Construir el formulario online respetando la codificación de preguntas.
22. Comunicar el propósito utilizando la narrativa explicativa.
23. Recoger las respuestas y cargarlas en una hoja de cálculo estructurada.
24. Calcular subíndices, IGM y, si procede, ROI.
25. Elaborar el reporte ejecutivo para comités/dirección.
26. Diseñar un plan de acción apoyado en los resultados.

8.2 Mantenimiento y evolución

El kit no es una reliquia, sino una base de trabajo:

- Revisión cada 12–18 meses para incorporar cambios normativos, nuevas guías o lecciones aprendidas.
- Ajuste de ponderaciones del IGM según prioridades (por ejemplo, mayor peso a resiliencia o a terceros).
- Inclusión de nuevos indicadores específicos (OT, DORA, marcos sectoriales).

9. Conclusión

El kit de encuesta ISO/IEC 27001:2022 sobre indicadores y métricas pretende bajar al terreno de juego lo que la norma, las guías de medición y los reguladores llevan tiempo diciendo: que sin indicadores bien definidos, bien medidos y bien utilizados, el SGSI corre el riesgo de ser más documental que operativo.

Este informe reúne todas las piezas: el cuestionario, su guía de uso, la narrativa para convencer a la organización, el mapeo normativo, la lógica de cálculo de madurez y ROI, el guion de reporte y las instrucciones de despliegue. Con ello, solo falta lo esencial: que las organizaciones se sienten, respondan honestamente y decidan qué quieren mejorar primero.
